

ACME Security Scan Report — September 2026

Scope: acme-platform monorepo. Severity per NVD. Classification: internal.

#	Package	Installed	CVE	Severity	Fixed in	Affected service
1	PyYAML	5.3.1	CVE-2020-14343	Critical (9.8)	5.4	billing
2	Jinja2	2.11.3	CVE-2024-22195, CVE-2024-34064	Medium	3.1.4 (use latest 3.1.x)	notifications
3	requests	2.25.1	CVE-2023-32681	Medium (6.1)	2.31.0 (use latest 2.32.x)	inventory

Notes

1. **PyYAML** — Loading untrusted YAML with the full loader can execute arbitrary code. Upgrading to 6.x also makes the `Loader` argument of `yaml.load` mandatory.
2. **Jinja2** — The `xmlattr` filter accepts attribute keys containing spaces / special characters, enabling XSS. Jinja2 3.1 removed `jinja2.Markup` and `jinja2.escape` (use `markupsafe`).
3. **requests** — `Proxy-Authorization` header can leak to the destination server on HTTPS redirects.

Policy: Critical within 24h, Medium within 14 days (stricter than PCI DSS v4.0.1 req. 6.3.3: critical patches within one month of release). Every fix needs passing tests and a changelog entry.